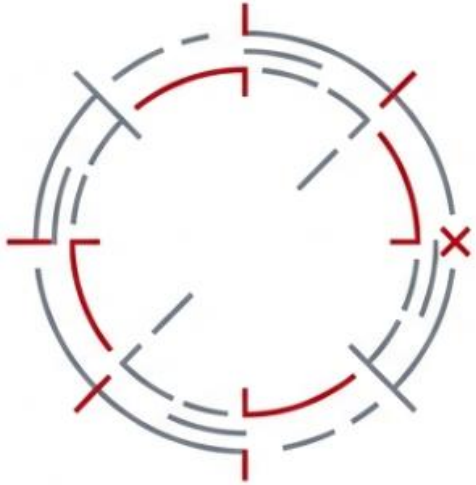
A10:2025 Mishandling of Exceptional Conditions

A10:2025
Mishandling of Exceptional Conditions
特殊情況處理不當



從程式碼品質到核心安全漏洞：防禦策略與實戰解析

A10:2025 Mishandling of Exceptional Conditions

為什麼「錯誤處理」成為 Top 10 安全風險？

Definition
當系統未能**預防、偵測或回應異常狀況**
（如網路中斷、邏輯錯誤、Timeout），
導致系統進入**未知或不安全狀態**。

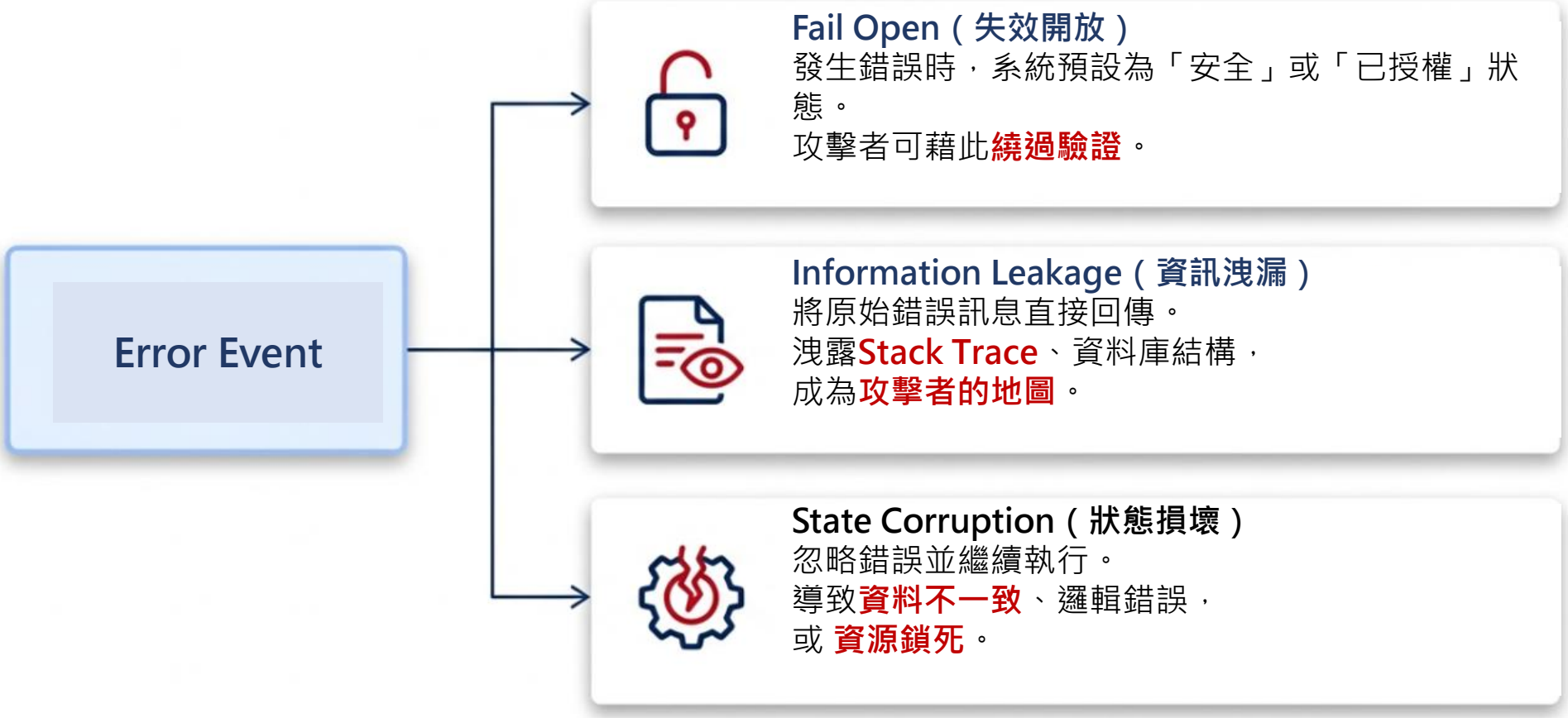
- **New Category：**
  2025 年新增類別，整合了 **24 個 CWE**
  （包含 **CWE-209、CWE-636**）。
- **Paradigm Shift：**
  過去被視為單純的「**程式碼品質差（Poor Code Quality）**」，
  現在被正式定義為**具體的安全漏洞**。
- **Insight（核心洞察）：**
  任何當應用程式**無法確定下一步指令**的時刻，
  即為**處理失當（Failure Handling Error）**。

Max Incidence Rate（最高發生率）

Total CVEs analyzed：3,416

A10:2025 Mishandling of Exceptional Conditions

核心病理：異常狀況如何演變成攻擊破口



A10:2025 Mishandling of Exceptional Conditions

臨床案例 1：授權機制失效（The Fail Open Error）

Scenario：
檢查使用者是否擁有刪除權限（canDeleteUser），
但**外部授權服務目前連線逾時**。

CWE-636

```
function canDeleteUser(int $actorId): bool {
    try {
        // 呼叫外部授權服務
        return AuthzService::check($actorId, 'user:delete');
    } catch (Throwable $e) {
        // [VULNERABILITY] Fail Open
        return true;
    }
}
```

Critical Flaw: Authentication Bypass if service crashes.

A10:2025 Mishandling of Exceptional Conditions

處方 1：預設拒絕（Fail Closed）

```php
function canDeleteUser(int $actorId): bool {
    try {
        return AuthzService::check($actorId, 'user:delete');
    } catch (Throwable $e) {
        // [SECURE] 記錄錯誤但預設拒絕
        error_log('authz_error: ' . $e->getMessage());
        return false;
    }
}
```

Secure: Deny by Default.

重點：

Deny by Default：
安全性優先於可用性。

Internal Logging：
錯誤細節僅留在 **Server-side log**。

A10:2025 Mishandling of Exceptional Conditions

臨床案例 2：洩露內部細節（The TMI Leak）

Server Code

```php
try {
    $user = findUser($_GET['id']);
    echo json_encode($user);
} catch (Throwable $e) {
    http_response_code(500);
    // [VULNERABILITY] 直接輸出 Exception 物件
    echo $e;
}
```

Browser/Attacker View

```
Fatal error: Uncaught Exception: SQLSTATE[HY000] [2002] Connection refused in /var/www/html/libs/db.php:23
Stack trace:
#0 /var/www/html/api/user.php(10): Database->connect()...
```

Reveals File Structure

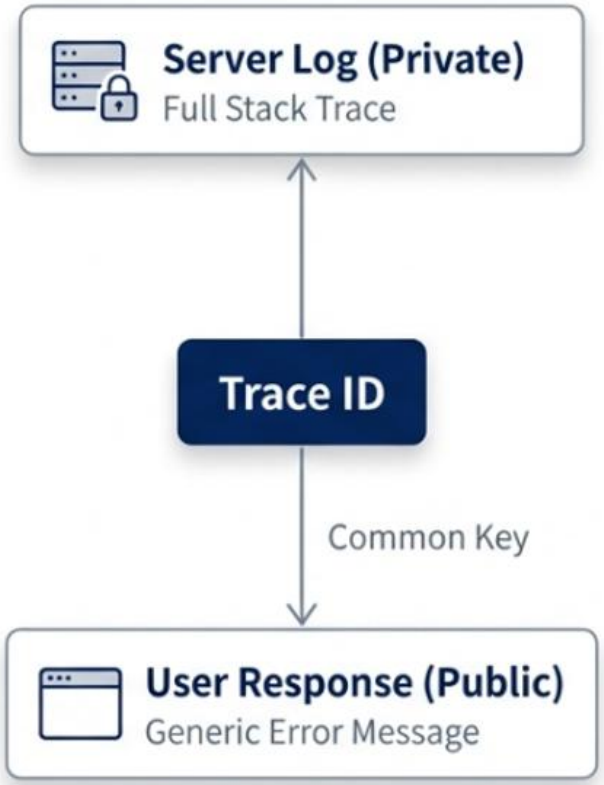
Reveals Database Tech

A10:2025 Mishandling of Exceptional Conditions

處方 2：清洗與追蹤（Sanitized Feedback）

```php
$traceId = bin2hex(random_bytes(8));
try {
    $user = findUser((int)($_GET['id'] ?? 0));
    echo json_encode($user);
} catch (Throwable $e) {
    // 內部記錄: 詳細資訊 + Trace ID
    error_log(json_encode(['trace_id' => $traceId,
        'msg' => $e->getMessage()]));

    // 對外顯示: 通用訊息 + Trace ID
    http_response_code(500);
    echo json_encode(['error' => 'Internal Server Error',
        'trace_id' => $traceId]);
}
```



A10:2025 Mishandling of Exceptional Conditions

臨床案例 3：隱形錯誤與狀態不一致（The Silent Killer）

Server Code

```
try {
    Payment::charge($orderId);
} catch (Throwable $e) {
    // [VULNERABILITY] 吞掉例外 (Swallowing Exception)
}
// 前端收到 200 OK，以為扣款成功
echo json_encode(['ok' => true]);
```

Visual Consequence

A10:2025 Mishandling of Exceptional Conditions

處方 3：原子性與明確失敗（Atomic Transactions）

```php
try {
    Payment::charge($orderId);
    echo json_encode(['ok' => true]);
} catch (Throwable $e) {
    error_log('payment_failed order={$orderId} err=' . $e->getMessage());

    // [SECURE] 明確回傳錯誤狀態碼
    http_response_code(502);
    echo json_encode(['ok' => false, 'error' => 'Service unavailable']);
}
```

Concept: Atomic Transaction

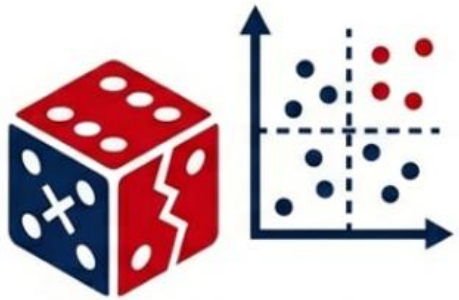
Fail Loudly + Rollback. Never leave the system in an unknown state.

A10:2025 Mishandling of Exceptional Conditions

系統層級防禦策略（Beyond the Code）

Rate Limiting（流量限制）
防止攻擊者利用 **Brute Force**，故意觸發大量請求或例外，
以消耗系統資源，進而造成 **DoS**

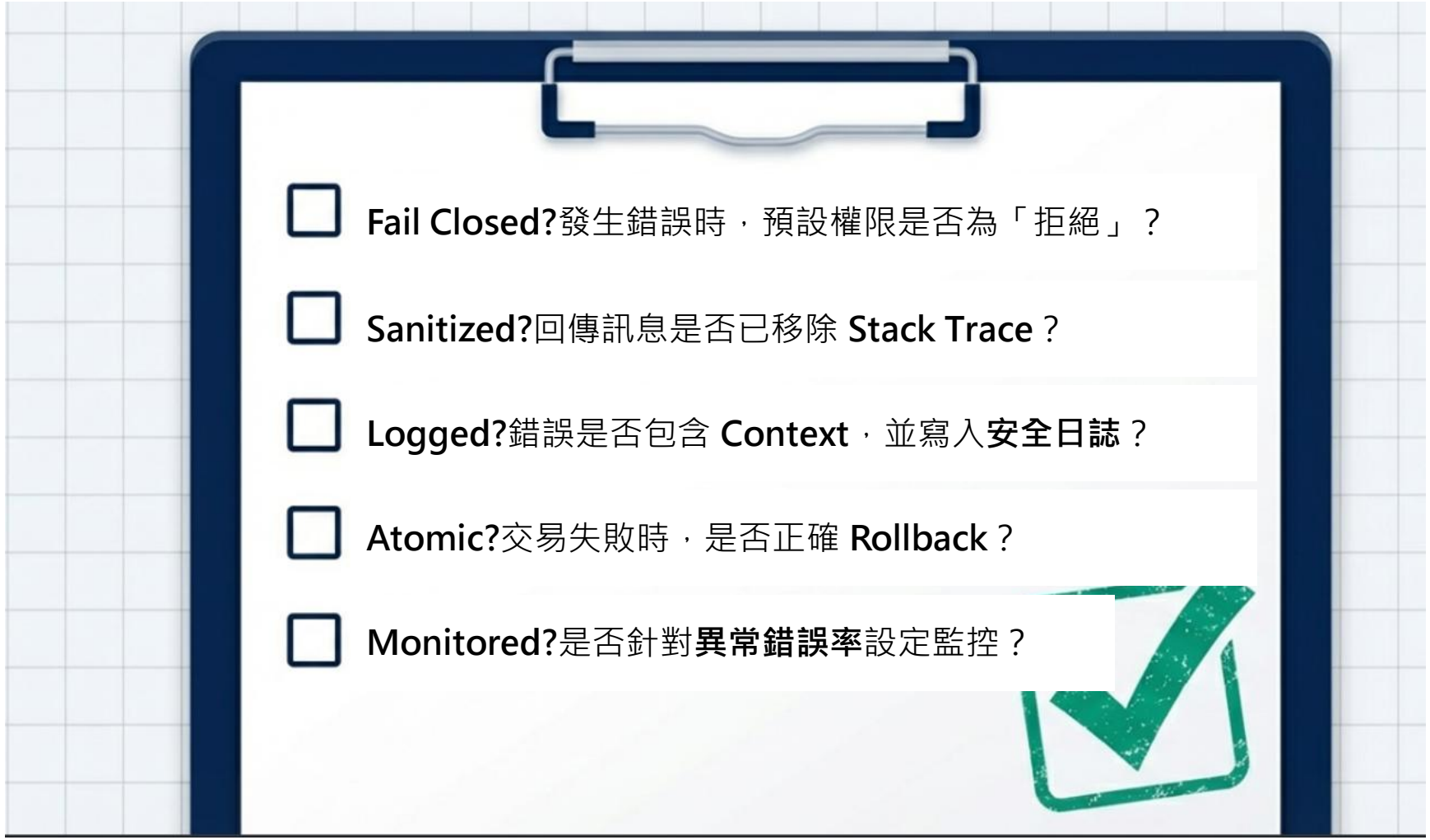
Centralized Handling（集中式處理）
建立全域處理器（**Global Exception Handler**），
確保所有錯誤都會經過**標準化、可控、清洗後的流程**再回傳



Chaos Engineering（混沌工程）
在 **QA 階段**刻意注入錯誤（例如：斷網、服務延遲、依賴失效），
驗證系統是否能夠正確地 **Fail Closed**

A10:2025 Mishandling of Exceptional Conditions

開發者自我檢核清單（Developer Checklist）



A10:2025 Mishandling of Exceptional Conditions

結語：建立具備韌性的應用程式

妥善處理異常狀況不僅是為了修復 Bug，
更是為了保護系統的機密性、完整性與可用性。

參考資料

OWASP Top 10: 2025 – A10 Mishandling of Exceptional Conditions
OWASP Cheat Sheet: Error Handling & Logging
OWASP ASVS v16.5: Error Handling Verification

Expect the worst, handle it best. (做最壞的打算，做最好的處理。)